IAM lessons from the week

October 9, 2026 | Prepared for Frank Andriulli III
Kraven Security: Triaging the Week 138 + Unsupervised Learning No. 546

Core idea: Control what a trusted identity can do, and retain evidence of who approved its access. These are selected newsletter reports; the lab exercises are suggested applications, not completed work.

1. AI agents need identity governance

Reported: Both newsletters describe agents misusing access or carrying malicious instructions across connected systems. [1, 2]

IAM lesson: Treat automation as a nonhuman identity: assign an owner, approved purpose, limited permissions, and a revocation procedure. A sandbox alone does not govern connected tools.

Lab practice: Use your service account as an automation stand-in. Record its owner, allowed resource, forbidden actions, and disablement procedure. Test one allowed action and one denied action.

2. Impersonation can undermine ordinary MFA

Reported: Kraven describes fake login windows and attackers relaying MFA prompts. [1]

IAM lesson: Verify high-risk reset requests through an established independent channel. FIDO2/passkeys bind authentication to the legitimate service; they do not make a compromised endpoint or stolen session harmless. [3]

Lab practice: Add a mock ticket to your delegated password-reset exercise: identity verification, authorized operator, action taken, and audit evidence.

3. Trusted integrations can become attack channels

Reported: Kraven reports malicious downloads promoted through trusted repositories and abuse of third-party messaging integrations. [1]

IAM lesson: A trusted brand is not an access-control decision. Scope API credentials narrowly and record ownership, review dates, and how access is revoked.

Lab practice: Create a practice integration entry using dummy credentials. Remove its resource-group membership, establish a fresh test session, and verify that the intended resource access is denied.

Protect, prove, explain

Apply the news to access reviews and the systems behind your lab.

4. Protect the virtualization management layer

Reported: Miessler links to an ESXi guest-to-host escape investigation. Huntress describes likely initial access through a compromised SonicWall VPN and a subsequent hypervisor attack. [2, 4]

IAM lesson: Host compromise can undermine controls inside every hosted VM. Remote access and virtualization administration deserve strong protection.

Lab practice: Your lab uses VirtualBox, not ESXi. Review host administrator access, host and hypervisor updates, and unnecessary host-guest sharing. This report does not establish that your lab has the ESXi flaw.

5. Authorization concepts transfer across platforms

Reported: Miessler includes a learning resource on Unix file and directory permissions. [2]

IAM lesson: Ownership, groups, ACLs, and effective permissions matter beyond Active Directory.

Lab practice: Explain your AGDLP path aloud: user -> role group -> resource group -> permission. Later, compare it with Linux owner/group permissions; no new VM is needed today.

Your next 15 minutes: service-account access review

Minutes 0-5: Record identity, owner, business purpose, approved access, actual access, and evidence location.

Minutes 5-12: Test one permitted action and one denied action. Save the results with the account, resource, and time. Do not enable interactive logon merely to make testing easier.

Minutes 12-15: Explain aloud: "If an attacker takes over this account, what can they reach, and how would I remove that access?"

Scope note

General reverse engineering and AI-companion coverage are lower priorities for this operational IAM brief. The public-key warning in Miessler's preview lacks enough explanation in the email body to conclude that public-key cryptography is broken.

Sources and further reading

[1] Kraven Security - Triaging the Week 138. Newsletter email reviewed.

[2] Daniel Miessler - Unsupervised Learning No. 546. Newsletter email reviewed; locate by this subject in your inbox.

[3] Microsoft Learn - Authentication methods: passkeys (FIDO2).

[4] Huntress - The Great VM Escape: ESXi Exploitation in the Wild.